

What is OWASP?

- OWASP = Open Web Application Security Project
- It's a non-profit community that focuses on improving web application security.
- They release a list called “OWASP Top 10”, which shows the most critical web app security risks developers should know.
- It helps developers understand where web apps are most often attacked, so they can secure their apps better.

OWASP Top 10

(2021 – Latest Version) 

Broken Access Control

- Users can access things they shouldn't (like admin pages).
-  Example: A normal user edits the URL /user/1 → /user/2 and sees someone else's data.

Cryptographic Failures

- Sensitive data isn't properly encrypted or protected.
-  Example: Passwords stored in plain text or weak encryption used for credit card info.

Injection (SQLi, NoSQLi, etc.)

- Attacker injects malicious code into queries or commands.
-  Example: Adding "' OR '1'='1'" in a login form to bypass authentication.

Insecure Design

- Security wasn't planned from the start (weak design).
-  Example: A website allows unlimited login attempts (no lockout system).

Security Misconfiguration

- Default settings or exposed error messages leak info.
-  Example: Admin panel publicly accessible with “admin/admin” login.

Vulnerable & Outdated Components

- Using old frameworks, libraries, or plugins with known bugs.
-  Example: Using an outdated version of WordPress or jQuery that hackers exploit.

Identification & Authentication Failures

- Weak login systems or session handling issues.
-  Example: Session doesn't expire after logout → attacker can reuse the token.

Software & Data Integrity Failures

- Using untrusted or modified code without verification.
-  Example: Installing a plugin from an unverified source that contains malware.

Security Logging & Monitoring Failures

- Attacks go unnoticed because they aren't logged properly.
-  Example: A hacker keeps trying different passwords, but no alert is generated.

Server-Side Request Forgery (SSRF)

- Attacker tricks the server into making requests to other systems.
-  Example: Hacker uploads a URL that makes the server fetch internal data like `http://localhost/admin`.